Team 1

Summit Federal Bank

Building, defending and recovering a bank's environment against a live attack

Carter Yanosick

Incident Commander · Windows, AD and compliance

Forensics and remediation · Linux and web

Presented to PNC leadership · October 22, 2026

01 · INFRASTRUCTURE AND HARDENING

Two servers hardened to PCI DSS standard

What we built

- Domain controller and file server (summitfed.local) with an internal CA
- Web host running the bank's web app over TLS
- SSH access only through Azure Bastion; no public IPs; key required.
- Isolated subnet (NSG) plus a host firewall on each server
- Synthetic customer records with truncated card numbers

120 → 23
inbound firewall rules on the DC, tested from the web host

0 → 6
lockout threshold; passwords now 14+ characters

19
audit categories turned on; legacy protocols removed

101 / 101
records restored and verified in a tested backup

Customer data: role-based access replaced "any domain user can modify" · encrypted in transit · every access audited

02 · THE ATTACK · OCTOBER 8

An attacker took over the DC and we caught it in 40 seconds

Time	What the attacker did	What we did
12:41	Logged on with the break-glass admin account	Detected at 12:42 by our monitoring script
12:56	Downloaded test malware (EICAR)	Blocked and removed by Defender
13:03	Created hidden admin account "svchelper"	Disabled, stripped, removed
13:10–13:26	Planted disguised task "WindowsUpdateHelper"	Found by baseline comparison
13:26	Erased the Security audit log	Timeline already preserved 3 minutes earlier

Vector: Azure Run Command, executing as SYSTEM and bypassing every network control

Impact: 0 of 101 customer records modified; all credentials reset

03 · LESSONS LEARNED

Detection worked; access to the cloud management plane was the gap

What worked

- Detection in 40 seconds from our own monitoring
- Named admin accounts and logging traced every action
- Evidence preserved before the attacker wiped the log
- Baselines caught what the logs could no longer show
- A tested backup meant recovery was never in doubt

What we would change

- Restrict who can run commands on servers from Azure
- Send logs off the server in real time (central SIEM)
- Vault the break-glass password; alert on every use
- Route every containment action through the IC
- Monitor state, not only events, on a schedule

Biggest Course Takeaways

01

Verify, don't assume

Never trust that a setting, patch or control is working because it says so. Check it, prove it, and check it again.”

02

Evidence before action

Preserve, attribute, then contain. Going straight to deletion would’ve deleted the evidence that we would’ve captured.

03

Teamwork makes or breaks

An incident without teamwork will lead to disaster. Working with your peers is an invaluable skill.

SUMMIT FEDERAL BANK · TEAM 1

Questions?

40 sec
to detect the intrusion

0 of 101
customer records modified

120 → 23
open firewall rules

2 of 2
persistence mechanisms found

Carter Yanosick ·